

SIMATS ENGINEERING
CO4 ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

*I **G.RAJU (192411065)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

G.RAJU

Signature of the student:

S.No.	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and Presentation(20)	Report is well structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

Vulnerability Assessment Report

1. Wireless Encryption

TJX used WEP while transitioning to WPA. WEP is obsolete and vulnerable to key-recovery attacks. Attackers who obtained wireless access could potentially intercept and decrypt network traffic.

Recommendation: Use WPA2-Enterprise or WPA3-Enterprise with strong encryption. Disable WEP and other legacy wireless protocols.

2. Authentication

Weak wireless access controls allowed unauthorized devices to connect to the retail network.

Recommendation: Implement enterprise authentication using 802.1X and RADIUS. Use individual user/device credentials instead of shared wireless passwords.

3. Network Segmentation

Sensitive payment systems were insufficiently isolated from wireless networks. Wireless compromise could therefore provide a path toward systems containing payment-card information.

Recommendation: Separate guest, corporate, wireless, POS, and payment-card networks using VLANs, firewalls, and access-control rules.

4. Monitoring

Inadequate monitoring reduced the organization's ability to detect unauthorized wireless access and suspicious network activity.

Recommendation: Deploy wireless intrusion detection/prevention systems (WIDS/WIPS), centralized logging, and continuous security monitoring.

5. Payment-Data Protection

Payment-card information requires strong protection against unauthorized access and transmission.

Recommendation: Apply PCI DSS controls, encrypt cardholder data, restrict access based on business need, regularly test security controls, and maintain appropriate audit logs.

Conclusion

The TJX incident demonstrates that obsolete encryption, weak authentication, poor segmentation, inadequate monitoring, and insufficient payment-data protection can combine to create a major breach. WPA2/WPA3 Enterprise, enterprise authentication, rogue-access-point detection, network segmentation, and PCI DSS controls would significantly reduce the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

Vulnerability Assessment Report

1. Authentication

The wireless network was insufficiently protected, allowing attackers to compromise a local wireless connection.

Recommendation: Use strong enterprise wireless authentication with 802.1X, RADIUS, and individual credentials.

2. Wireless Isolation

The compromised wireless connection was able to reach central corporate systems and other retail locations.

Recommendation: Isolate wireless clients and place wireless networks in dedicated VLANs. Wireless users should not have direct access to corporate or POS networks.

3. Firewall Controls

Insufficient firewall restrictions allowed traffic from the compromised wireless environment to reach sensitive internal systems.

Recommendation: Deploy firewalls between wireless, corporate, POS, and management networks. Apply least-privilege firewall rules.

4. POS Segmentation

Point-of-sale systems should have been separated from general wireless and corporate networks.

Recommendation: Create a dedicated POS network with strict access-control lists and firewall policies.

5. Intrusion Detection

Improved intrusion detection could have identified unusual wireless and internal network activity.

Recommendation: Deploy IDS/IPS and wireless intrusion detection with centralized alerts.

6. Centralized Access Management

Wireless access should be centrally managed and authenticated.

Recommendation: Use centralized RADIUS/identity management, role-based access control, device authentication, and regular credential review.

Conclusion

The major weakness was that a local wireless compromise could provide access to a much larger corporate environment. Strong authentication, wireless isolation, firewall controls, POS segmentation, IDS/IPS, and centralized access management would reduce this risk.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, sessioncookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and usersecurity awareness.

Vulnerability Assessment Report

1. Open-Network Authentication

Open Wi-Fi networks allow users to connect without strong authentication and do not inherently protect application traffic.

Recommendation: Use secure Wi-Fi authentication where practical and provide clear security guidance to users.

2. Session-Cookie Protection

Unencrypted session cookies could be captured by another user on the same network and reused to impersonate an authenticated user.

Recommendation: Set cookies with Secure and HttpOnly attributes and use short-lived session tokens.

3. HTTPS Enforcement

Protecting only the login page is insufficient if subsequent application traffic uses HTTP.

Recommendation: Enforce HTTPS for the entire website and all authenticated sessions.

4. HSTS

Without HSTS, users may be vulnerable to downgrade or accidental HTTP connections.

Recommendation: Implement HTTP Strict Transport Security (HSTS) with appropriate configuration.

5. VPN Use

Users on public Wi-Fi can benefit from encrypted VPN connections.

Recommendation: Encourage or provide a trusted VPN for users accessing sensitive services over public networks.

6. Wireless Client Isolation

Clients connected to the same Wi-Fi network should not be able to directly communicate with each other.

Recommendation: Enable wireless client/AP isolation to reduce local session-sniffing and peer-to-peer attack opportunities.

7. User-Security Awareness

Users may not understand the risks of open Wi-Fi.

Recommendation: Educate users to verify HTTPS, avoid sensitive transactions on untrusted networks, use VPNs, and keep devices updated.

Conclusion

Firesheep demonstrated that open Wi-Fi combined with insecure HTTP sessions could enable session hijacking. Full HTTPS, HSTS, secure cookies, VPNs, client isolation, and user awareness significantly reduce this risk.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

Vulnerability Assessment Report

1. Guest Authentication

Hotel Wi-Fi authentication mechanisms can be abused if credentials or guest identity information are poorly protected.

Recommendation: Use secure authentication, strong encryption, and separate guest credentials from administrative accounts.

2. Captive-Portal Security

Captive portals can be manipulated to distribute fraudulent content or redirect users.

Recommendation: Secure captive portals with HTTPS, certificate validation, secure authentication, and integrity monitoring.

3. DNS Integrity

Manipulated DNS could redirect guests to malicious websites or fake update pages.

Recommendation: Protect DNS infrastructure, monitor DNS traffic, and use trusted DNS services with appropriate security controls.

4. Network Segmentation

Guest devices should never have direct access to hotel management systems.

Recommendation: Separate guest Wi-Fi, POS, administrative, IoT, and management networks using VLANs and firewalls.

5. Third-Party Access

Hotel Wi-Fi may depend on external vendors for network management.

Recommendation: Apply least privilege, MFA, contractual security requirements, access logging, and regular vendor-access reviews.

6. Digital-Signature Verification

Fraudulent software updates can distribute malware if users accept unsigned or improperly verified software.

Recommendation: Require cryptographically signed software updates and ensure systems verify digital signatures before installation.

7. Malware Detection

Endpoint security is necessary to detect malicious downloads.

Recommendation: Deploy EDR/antimalware, application control, and network-based malware detection.

8. Monitoring of Privileged Systems

Administrative systems are high-value targets.

Recommendation: Monitor privileged accounts, administrative logins, configuration changes, DNS activity, and unusual network traffic.

Conclusion

DarkHotel demonstrates the risks of compromised hotel networks and fraudulent software updates. Secure captive portals, DNS protection, segmentation, vendor controls, signed updates, endpoint security, and continuous monitoring can significantly reduce the risk.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable use policies, and legal consequences.

Vulnerability Assessment Report

1. IEEE 802.11 Deauthentication Frames

Traditional Wi-Fi management frames can be transmitted without adequate protection, allowing forged deauthentication frames to disconnect legitimate clients.

Recommendation: Implement Protected Management Frames (PMF/802.11w).

2. Availability Risks

Deauthentication attacks primarily affect availability by repeatedly disconnecting legitimate users.

Recommendation: Deploy wireless intrusion detection/prevention systems capable of detecting and responding to abnormal management-frame activity.

3. Wireless Interference

Unauthorized transmission of management frames can interfere with legitimate wireless services.

Recommendation: Continuously monitor the RF environment and identify unauthorized transmitters and abnormal wireless behavior.

4. Protected Management Frames

PMF protects important management traffic from unauthorized manipulation.

Recommendation: Enable and require PMF where supported, particularly for modern enterprise wireless deployments.

5. WPA3 Requirements

WPA3 provides modern wireless security improvements and supports stronger protection for management traffic.

Recommendation: Migrate to WPA3-Enterprise where compatible and use PMF as part of the wireless security architecture.

6. Wireless Intrusion Detection

Wireless monitoring can identify repeated deauthentication attempts and suspicious devices.

Recommendation: Deploy WIDS/WIPS and integrate alerts with the organization's security monitoring system.

7. Acceptable-Use Policies

Wireless equipment should only be used for authorized purposes.

Recommendation: Establish clear acceptable-use policies, technical restrictions, employee training, and approval procedures.

8. Legal Consequences

Unauthorized interference with wireless communications can create regulatory and legal consequences.

Recommendation: Ensure wireless-security practices comply with applicable telecommunications regulations and organizational policies.

Conclusion

The incident demonstrates that unprotected wireless management frames can create serious availability risks. PMF, WPA3, WIDS/WIPS, RF monitoring, acceptable-use policies, and legal compliance controls can reduce the risk.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

Vulnerability Assessment Report

1. SSID Trust

Users may assume that a familiar-looking SSID belongs to the legitimate organization.

Recommendation: Educate participants not to trust SSID names alone and publish the official network details through trusted channels.

2. Automatic Reconnection

Devices may automatically reconnect to previously used networks.

Recommendation: Disable automatic connection to unknown or unsecured networks and remove unused saved networks.

3. Captive-Portal Authentication

Fake access points can imitate legitimate captive portals and collect information.

Recommendation: Use HTTPS-protected portals, certificate validation, and clear verification procedures.

4. Evil-Twin Detection

Fake access points can imitate legitimate SSIDs.

Recommendation: Deploy wireless intrusion detection systems to identify duplicate or unauthorized SSIDs and suspicious access points.

5. Certificate Validation

Users may ignore certificate warnings and connect to fraudulent services.

Recommendation: Enforce certificate validation and educate users never to bypass browser certificate warnings.

6. VPN Enforcement

VPNs can provide additional protection when users connect through untrusted networks.

Recommendation: Require VPN use for sensitive organizational activities.

7. Participant Awareness

Users are an important part of wireless security.

Recommendation: Provide security awareness training covering fake Wi-Fi, automatic connections, HTTPS, VPN use, and suspicious login pages.

Conclusion

Fake Wi-Fi networks demonstrate that SSID names alone cannot establish network trust. Evil twin detection, certificate validation, VPN enforcement, secure captive portals, and participant awareness can reduce the risk.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

Vulnerability Assessment Report

1. Public-Network Authentication

Hotel and event Wi-Fi networks are outside the organization's direct control.

Recommendation: Treat public Wi-Fi as untrusted and require secure authentication and encrypted connections.

2. Credential Protection

Attackers may attempt to steal credentials through compromised or fraudulent Wi-Fi networks.

Recommendation: Use strong passwords, password managers, phishing-resistant authentication where possible, and never transmit credentials over insecure connections.

3. Multifactor Authentication

A stolen password should not be sufficient to access sensitive systems.

Recommendation: Implement MFA for email, cloud applications, administrative systems, and sensitive organizational resources.

4. Device Certificates

Device certificates can help verify authorized devices.

Recommendation: Use certificate-based authentication for managed devices and enterprise wireless access.

5. Endpoint Security

Traveling officials may connect to unfamiliar networks.

Recommendation: Use centrally managed endpoint protection, EDR, encryption, security updates, and device-control policies.

6. VPN Configuration

Sensitive organizational traffic should be encrypted over untrusted networks.

Recommendation: Configure an enterprise VPN with strong authentication and automatic connection when using public networks.

7. Travel-Security Policies

Traveling personnel require specific security procedures.

Recommendation: Establish travel-security policies covering public Wi-Fi, device handling, credential protection, software updates, and reporting of suspicious activity.

8. Medical Information Protection

Anti-doping organizations may handle sensitive medical information.

Recommendation: Apply strong access control, encryption, data minimization, audit logging, and least-privilege access to medical information.

Conclusion

Officials using hotel and event Wi-Fi face significant credential and data-exposure risks. MFA, device certificates, endpoint security, VPNs, travel-security policies, and strong protection of medical information can reduce these risks.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise WiFi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

Vulnerability Assessment Report

1. RF Exposure Outside the Physical Perimeter

Wireless signals can extend beyond an organization's physical boundary, allowing attackers nearby to attempt attacks without entering the building.

Recommendation: Perform regular wireless RF assessments and use appropriate access-point placement and power management.

2. Enterprise Wi-Fi Authentication

Weak authentication could allow unauthorized devices to connect.

Recommendation: Use WPA2-Enterprise or WPA3-Enterprise with 802.1X and centralized authentication.

3. 802.1X

802.1X provides port-based network access control and helps ensure that only authorized users/devices connect.

Recommendation: Deploy 802.1X with RADIUS for enterprise wireless authentication.

4. EAP Certificate Validation

Improper certificate validation can expose users to rogue authentication servers and credential theft.

Recommendation: Configure managed devices to validate trusted server certificates and certificate authorities.

5. Rogue-Device Detection

Unauthorized access points or attack equipment near the premises may be used to compromise wireless users.

Recommendation: Deploy WIDS/WIPS to detect rogue access points, evil twins, and suspicious RF activity.

6. Wireless Intrusion Prevention

Detection alone may not be sufficient for high-security environments.

Recommendation: Use wireless intrusion-prevention capabilities to identify and respond to unauthorized wireless activity according to approved procedures.

7. Physical Surveillance

Wireless attacks can be performed from outside the building.

Recommendation: Combine wireless monitoring with CCTV, access control, perimeter monitoring, and security patrols.

8. Network Access Control

Even if a device connects to Wi-Fi, access should be restricted according to its identity and security status.

Recommendation: Implement NAC to verify users and device security posture before granting network access.

Conclusion

The incident demonstrates that wireless security must extend beyond the physical perimeter. Enterprise authentication, 802.1X, EAP certificate validation, WIDS/WIPS, NAC, RF monitoring, and physical surveillance can reduce the risk.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue-access-point detection, staff response procedures, and user-verification methods.

Vulnerability Assessment Report

1. SSID Impersonation

Attackers can create access points using names similar to legitimate airport or airline Wi-Fi networks.

Recommendation: Deploy rogue-access-point detection and clearly communicate official SSIDs to passengers.

2. Captive-Portal Authentication

A fraudulent captive portal may collect usernames, passwords, or personal information.

Recommendation: Use HTTPS-protected captive portals and provide clear verification information.

3. Automatic Connection

Devices configured for automatic Wi-Fi connection may connect to fraudulent networks.

Recommendation: Disable automatic connection to unknown networks and remove unnecessary saved SSIDs.

4. Certificate Warnings

Fraudulent websites may produce certificate warnings.

Recommendation: Educate users never to ignore certificate warnings and ensure legitimate services use valid certificates.

5. Passenger-Data Exposure

Passengers may expose credentials, personal information, emails, and other sensitive data through fraudulent networks.

Recommendation: Require HTTPS, encourage VPN use, minimize sensitive transactions over public Wi-Fi, and educate passengers.

6. Rogue-Access-Point Detection

Airports and airlines can detect unauthorized wireless equipment.

Recommendation: Deploy WIDS/WIPS and continuously monitor the RF environment.

7. Staff Response Procedures

Staff must respond quickly when an unauthorized access point is detected.

Recommendation: Establish procedures for identifying, reporting, investigating, and safely removing or isolating rogue access points.

8. User-Verification Methods

Passengers need an easy method to identify legitimate Wi-Fi.

Recommendation: Display the official SSID through airport screens, websites, staff communications, and signage. Do not rely only on SSID names for security.

Conclusion

Evil-twin access points can exploit user trust and automatic device connections. Rogue-AP detection, secure captive portals, certificate validation, VPN use, staff procedures, and clear user-verification methods can reduce the risk.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

Vulnerability Assessment Report

1. Privileged-Access Management

Misuse of a legitimate administrator account indicates that privileged accounts require stronger controls.

Recommendation: Implement Privileged Access Management (PAM), least privilege, privileged-account separation, and regular access reviews.

2. Multifactor Authentication

A compromised administrator credential may allow unauthorized access if only a password is required.

Recommendation: Require MFA for all administrative and supplier accounts.

3. Captive-Portal Security

The public Wi-Fi landing page can be manipulated if administrative access is compromised.

Recommendation: Restrict portal administration, use secure authentication, protect administrative interfaces, and continuously monitor portal changes.

4. Third-Party Supplier Access

Public Wi-Fi services may be operated or maintained by external suppliers.

Recommendation: Apply least privilege to supplier accounts, require MFA, review supplier access regularly, and establish contractual security requirements.

5. Logging

Without adequate logs, identifying the source and scope of unauthorized changes becomes difficult.

Recommendation: Maintain centralized and tamper-resistant logs for administrator logins, configuration changes, portal modifications, and authentication events.

6. Change Approval

Unauthorized changes to public-facing systems can affect many users.

Recommendation: Implement formal change-management procedures requiring approval, testing, documentation, and rollback plans.

7. Account Monitoring

Legitimate accounts can be abused by attackers.

Recommendation: Monitor privileged accounts for unusual login locations, times, devices, failed logins, and unexpected configuration changes. Generate alerts for suspicious activity.

8. Incident-Response Procedures

The affected services were suspended while the incident was investigated, demonstrating the importance of a rapid response capability.

Recommendation: Maintain an incident-response plan covering account compromise, service suspension, credential reset, forensic investigation, communication, recovery, and postincident review.

Conclusion

The incident demonstrates that legitimate administrator accounts can become a major attack path when privileged access, MFA, supplier access, logging, change management, and

monitoring are inadequate. Strong PAM, MFA, centralized logging, controlled changes, account monitoring, and effective incident response can significantly reduce the risk.